Submission supplement

Verifiable Crypto-Erasure for Cross-Border Health Data Audit Trails under the European Health Data Space

Arshad Akhtar Abbasia
MSc in Sustainable Energy Logistics, Faculty of Logistics, Høgskolen i Molde
Supervisor: Prof. João Ferreira
14 November 2026

1 **Reproduce in five minutes**
One page: the commands, the numbers you should see, and where they appear in the thesis.

2 **Verification dossier**
Three hostile reviews of the thesis, a two-pass audit of the code, and a search for prior art: what each found and how each finding was resolved.

3 **Evidence map**
Every load-bearing claim, the section that makes it, the code that checks it and the test that guards it.

4 **Policy brief, English**
Two findings for the Norwegian authorities who will set retention for the cross-border audit trail.

5 **Notat, norsk**
The same brief in Norwegian.

What is submitted

The submission at a glance

The thesis is the examined work. Everything else here lets a reader check it: run the code, see what hostile reviewers found and how it was fixed, follow any claim to the code that tests it, and read what the findings mean for the authorities who will act on them.

Item	Where	What it is for
Thesis	VERA-SNARK_Thesis_SUBMISSION (Word and PDF)	The examined text: seven chapters, Appendices A to D, references.
Live demonstration	trfhimolde.streamlit.app	The running code, page by page. It reproduces Chapter 5 when opened and shows a notice beside any figure that differs.
Archived code	doi.org/10.5281/zenodo.23989242	Release 1.3.0, the code Appendix A reproduces. All versions: doi.org/10.5281/zenodo.23819274.
This supplement	Five parts, listed on the cover	Material that supports the examination without being part of the examined text.
Repository	github.com/Astheno-sphere/TRF-thesis, branch joao-base	Thesis, code (demo_app/), reproduction package, full history, change trail and inspector.

> Nothing in this supplement adds a claim to the thesis. Where it summarises, the thesis section is named; where it reports a check, the check can be rerun from the archived code.

Part 1

Reproduce in five minutes

Python 3.11 to 3.13; the checker needs only the standard library. The run is deterministic under seed 20260915, so your output matches the thesis byte for byte.

1 **Get the code**

```
git clone -b joao-base https://github.com/Astheno-sphere/TRF-thesis && cd TRF-thesis/demo_app
```

or download release 1.3.0 from Zenodo

2 **Run the checker**

```
python3 trf_checker.py
```

standard library only, under a second

3 **Run the tests**

```
pip install -r requirements.txt pytest && python3 -m pytest -q tests/
```

56 passed

4 **Run everything**

```
cd ../repro_package && ./run_all.sh
```

seven diffs, all empty

The fastest single check. The auditor view of record 100 prints its commitment. If it matches, you are running the reported code and seed; the seven diffs of step 4 check the rest.

678ade47c1e6dc03…

What you should see

Result	Value	Thesis
Semantics I, total violations	**95**	Table 5.3
Semantics I, records with a violation	**90 of 200**	Table 5.3
Corollary 1.2 witnesses, no erasure request	**39**	§5.4
Exhaustive cross-check, three conflict cases	**no satisfying assignment**	Table 5.4
Records invalidated (Art. 17 / Art. 68(12))	**138 (52 / 86)**	Table 5.6
Semantics II, total violations	**0**	Table 5.6
Records verifying against the audit log	**200 of 200**	§5.7
Figures changed by Synthea (synthetic) payloads	**none**	Table 5.7

Bounded Z3 check, no counterexample	**9 of 9**	§5.5

Part 2

Verification dossier

Six reviews between 28 October and 6 November 2026: three by AI agents set to attack the thesis, one by the supervisor, one search of the literature and law, and an AI audit of the code in two passes. Every finding was checked against its source before anything changed, and every change went through a gated patch recorded in the thesis repository's change trail.

Review	What it attacked	What changed
Red team, round 1 28 Oct 2026	Seven simulated reviewers, each attacking one flank: a cryptographer, a formal-methods purist, a data-protection lawyer, a systems engineer, a logistics professor, a prior-art hunter and a relevance sceptic.	A prepared answer for each; current case law and guidance found and cited (P85 to P87).
Red team, round 2 31 Oct 2026	Two AI agents on the revised text: an examiner panel and a consistency and citation audit.	Sub-questions answered one by one in Chapter 7; the legal condition of Corollary 1.2 carried into constraint C3; citations re-verified.
Supervisor review 2 Nov 2026	Prof. Ferreira's feedback, each item checked against the text before acting.	41 verified edits (P102, P103): the two principal interpretive steps named at all nine sites with four subsidiary premises; search counts; retention floor led by the sourced value.
Examiner red team, round 3 2 Nov 2026	An AI agent acting as external examiner on the full text: logical soundness, legal reading, method, consistency.	26 verified edits (P109); five argument-level points decided by the author and written in (P112): the policy status of the pilot floor, the dependence of Proposition 1 on Section 4.2, the premise of Corollary 1.2, the identifier case, and what "verifiable" qualifies.
Prior-art and new-law search 2 Nov 2026	Literature and law to November 2026, including Norwegian sources.	No work found that models floor, right and ceiling together. Three updates written in: EDPS v SRB (C-413/23 P), Implementing Regulation (EU) 2026/2083, the designation of Folkehelseinstituttet.
Code audit, two passes 6 Nov 2026	An AI code review in the style of CodeRabbit, then a deeper read-only pass for what it missed.	First pass: 1 critical, 16 major, 14 minor. Second pass: 1 critical, 5 major, 7 minor. Each checked before acting; one left to the author; every re-runnable recorded run still byte-identical (the full-cohort record keeps its old result wording); release 1.3.0.

> What held throughout: the four propositions, every result figure in Chapter 5, and the novelty of modelling the retention floor, the right to erasure and the deletion ceiling together.

The code audit

The critical and major findings of both passes and how each was resolved. Evidence and verification for every row are in CODE_REVIEW.md in the thesis repository; the next pages show the changes themselves.

Finding	Severity	Fault, then fix
C1	Critical	**The reproduction README gave the wrong reference commitment for record 100.** Value corrected in both repositories; the integrity table rebuilt row by row from the recorded run.
P2-C1	Critical	**The first fix for the growing audit log attached records to a log only when first invalidated.** The log is bound to each record when it is created; every population starts its own.
M1	Major	**The 54 tests cited by the thesis were not in the thesis repository.** demo_app/ now carries the tests and the recorded runs.
M2, M6, M7	Major	**Documented reproduction commands failed from the folders they were written for.** Appendix A.5 states where commands run; paths corrected; the realism layer finds the repository's one copy of the subset.
M3	Major	**The audit log was described as tamper-evident without a limit.** Thesis (§5.7) and code state the scope: divergence between a record and its log is detected; a rewrite of the log needs a published root, specified in §6.1 and not built.
M4	Major	**Semantics II "0 violations" read as a test of C2 and C3.** §5.7 names the integrity check as the part of the result that can fail.
M5	Major	**The exhaustive cross-check answered wrongly when its horizon left retention months unexamined.** The function refuses such a horizon; the checker also compares it with itself on its four cases and fails on disagreement.
M8	Major	**The hosted app grew its audit log with every rerun.** One log per population (see P2-C1).
M9 to M11	Major	**Deployment and reproduction READMEs carried superseded figures and table numbers.** Rewritten from Chapter 5 and the recorded run.
M12, M13	Major	**The trail inspector could not pass outside the author's machine.** Loud failures; pandoc checked; ranges read; check 14 replays each file from the state its first logged patch began from.
M14	Major	**The submission Word file was the one artefact no gate inspected.** Page numbers by default; failure on missing content or tools; atomic write with a CRC check; new inspector check 15.
M15, M16	Major	**Two inspectors could pass vacuously or read the wrong file.** Checksums cover this repository's copies; concordance anchored to the repository and fails on zero.
P2-M1	Major	**Line counts disagreed across Table 5.1, §5.2 and Appendix A.** Regenerated from the files (P117, P121); four Appendix A listing headers missed then were corrected on 9 Nov (P125).

P2-M2	Major	**Chapter 5 said the reported run uses Synthea payloads.** §5.2 corrected; Synthea serves §5.8 only.
P2-M3	Major	**Two Synthea cohorts were conflated.** Both named in the provenance statement and the subset README, in both repositories.
P2-M4	Major	**The cross-sector "no violations" did not test the whole log entry the § 17 limit reaches.** §6.10 states the narrower zero.
P2-M5	Major	**Personal and process material is public: supervisor review files, the Helsedirektoratet correspondence, a hash map naming commit rewrites.** Not changed: the author's decision. The repositories stay public until the author makes them private; Appendix D is reproduced with the sender's permission.

> The minor findings of both passes were fixed or documented, among them: decryption that crashed on an unauthenticated ciphertext, a Z3 run with no timeout, an exit status that ignored tampering, an app verdict that said "holds" on failure, a record strip drawn rather than computed, and wording that called synthetic payloads real. Two printed lines changed on purpose and were re-recorded; no result figure in the thesis changed.

Part 2, continued

The fixes, in the code

Six of the changes as they stand in git: the lines before, the lines after, what the change does, and the test or check that fails if it is undone. Releases 1.2.0 and 1.3.0 of the code bracket them.

P2-C1. One audit log per population, bound at creation

`trf_checker.py, TRF 067baec`

```
- def log_creation(rec):
-     if getattr(rec, "log_idx", None) is None:
-         rec.log_idx = {"access": AUDIT_LOG.append(_creation_entry(rec))}
+ def __init__(self, rid, t_a, floor, sigma, payload, t_r=INF, t_pi=INF, log=None):
+     self.log = log if log is not None else AUDIT_LOG
+
+ def generate(n_primary=100, n_secondary=100, seed=SEED):
+     log = new_log()
+     ...Record(rid, t_a, FLOOR_XBORDER, "primary", payload, t_r=t_r, log=log)
```

Every record now writes to the log of its own population. Another run, or another visitor on the hosted app, can no longer append to it.

Guarded by test_each_population_keeps_its_own_log

M5. The cross-check refuses a horizon it cannot cover

`trf_checker.py, TRF fb2650e`

```
- def brute_force_semantics_I(t_a, floor, t_r, t_pi, sigma, horizon):
-     e_dl = t_r + DELTA if t_r < INF else INF
+ def brute_force_semantics_I(t_a, floor, t_r, t_pi, sigma, horizon):
+     if horizon <= t_a + floor:
+         raise ValueError(f"horizon {horizon} must exceed t_a + floor = {t_a + floor}")
+     e_dl = t_r + DELTA if t_r < INF else INF
```

A horizon that ends inside the retention window used to return feasible for months never examined; it now stops.

Guarded by test_brute_force_rejects_short_horizon

Exit. The run fails when any check fails

`trf_checker.py, TRF 067baec`

```
- return 0 if total_v2 == 0 else 1
+ detected = not (ok_t or ok_g or ok_p)
+ return 0 if (total_v2 == 0 and cross_ok and n_ok == len(records) and detected) else 1
```

A cross-check disagreement, a record failing its inclusion proof or an undetected tamper now exits non-zero.

Guarded by CI on Python 3.11 to 3.13

Minor. An unauthenticated ciphertext counts as refused

`crypto_envelope.py, TRF fb2650e`

```
- except KeyError:
-     refused += 1
+ except (KeyError, InvalidTag):
+     refused += 1
```

A tampered ciphertext used to crash the run instead of being counted as unreadable.

Guarded by recorded run, byte-identical

M14. The submission file is written atomically and checked

`handoff_tools/build_docx.py, thesis f204d54`

```
- with zipfile.ZipFile(OUT, "w", zipfile.ZIP_DEFLATED) as z:
+ if not (tables and toc and nlinks):
+     raise SystemExit("build_docx: refusing to write ...")
+ tmp = OUT.with_name(OUT.name + ".tmp")
+ with zipfile.ZipFile(tmp, "w", zipfile.ZIP_DEFLATED) as z: ...
+ os.replace(tmp, OUT)
```

The Word file is never half-written, and a build that lost its tables, contents or links stops instead of overwriting it.

Guarded by trail_check check 15

M13. The full replay starts each file where its log begins

`handoff_tools/trail_check.py, thesis f204d54`

```
- if r["patch"].startswith("D0_"):
-     continue
- state[f] = subprocess.run(["git", "show", f"{TAG}:{f}"], ...).stdout
+ first_before.setdefault(r["file"], r["before"])
+ state[f] = start_state(f)   # tag copy, or the committed blob whose md5
+                             # equals the first logged "before" md5
```

The replay failed by construction since October. It now replays all 48 files exactly, so the patch log accounts for every change it took over.

Guarded by trail_check check 14

Part 3

Evidence map

Each load-bearing claim, the section that makes it, the code that checks it, and what fails if the code stops agreeing with the thesis. Proposition 4 is argued, not executed, and is listed so that the gap is visible.

Claim	What it says	Thesis	Checked by	Guarded by
Proposition 1	Under plaintext verifiability the three obligations are infeasible whenever a deadline falls inside the retention window.	§4.6	`check_semantics_I; brute_force_semantics_I; z3_check P1`	recorded run; cross-check test (31 cases); Z3 P1 (both directions)
Proposition 2	Under accountability-preserving verifiability they are jointly satisfiable for every record, request pattern and floor.	§4.7	`check_semantics_II; V_II; integrity`	recorded run; 3 tamper tests; exit status
Proposition 3	A ceiling collides with a floor if and only if the ceiling ends no later than the floor.	§4.6	`z3_check P3; cross_sector_check`	Z3 with off-by-one mutation
Proposition 4	Moving a record out of the regulated environment meets the ceiling but not the right (stated premise).	§4.10	`argued, not executed`	premise listed in §3.7
Corollary 1.2	Infeasibility without any erasure request, on the broad reading of Art. 68(12), for logs kept at patient-record granularity.	§4.6, §5.4	`cor12 count in trf_checker`	ledger: 39 witnesses
95 / 90 of 200	Semantics I violations and records.	Table 5.3	`trf_checker.main`	byte-identical recorded run
138, 52 / 86, 0	Invalidations, their grounds, Semantics II violations.	Table 5.6	`apply_invalidation; check_semantics_II`	recorded run; ledger
200 of 200	Records verifying against the audit log root.	§5.7	`MerkleLog; integrity`	tamper tests must fail
Payload independence	No figure moves with Synthea (synthetic) payloads.	Table 5.7	`synthea_layer`	exit status on divergence
Attested, not proven	Key destruction is simulated; the residue is pseudonymised, not anonymous.	§4.8, §4.9	`crypto_envelope; docstrings`	stated in code, app and thesis

> The viewer's claim ledger recomputes every Chapter 5 figure each time it opens, and an automated test fails if any of them, or any proposition the viewer quotes, departs from the thesis text.

Part 4, policy brief

Retention of the cross-border audit trail: two findings for the controller

Written for Helsedirektoratet (NCPeH controller), Datatilsynet, and the Ministry of Health and Care Services

A cross-border exchange through MyHealth@EU leaves an audit record that must be kept, so it can be audited, and that the patient may ask to have erased (GDPR Article 17). An access log in a Secure Processing Environment faces a third duty: deletion within six months of the permit's end (EHDS Article 68(12)). No instrument says how these duties fit together.

1 **The six-year pilot period is a controller's decision with no identified legal basis.**

Helsedirektoratet finds no retention period in the eHDSI specifications, which refer to national law; six years was decided for the pilot, and the production period is undecided and is Helsedirektoratet's to set as controller (Appendix D). The MyHealth@EU implementing regulation, (EU) 2026/2083, requires exchanges to be logged but also sets no period. Article 17(3)(b) GDPR exempts processing needed for a legal obligation, or a public task, laid down in Union or Member State law. Unless a national legal basis for the six years is identified, keeping the patient link against an erasure request before Article 9 EHDS applies on 26 March 2029, and after its 36 months, has no secure basis under Article 17(3)(b).

2 **Keeping and erasing can both be met, if "verifiable" means accountable.**

If an audit record must stay readable to count as verifiable, the duties cannot all be met whenever a deadline falls inside the retention period. If it is enough to keep who acted, when, a cryptographic commitment to the content and a logged invalidation entry, then in the model they can be met for every record: the content goes at its deadline and the record stays checkable. The thesis specifies a mechanism for this and checks it in code on synthetic data.

Questions put to the authorities (Chapter 7, §7.4)

- On what legal basis will the production retention period rest?
- Does an audit record whose content has been invalidated still satisfy a retention obligation?
- Does Article 68(12) reach access logs kept per patient record?

Limits. Results come from a formal model checked on synthetic data, not from a deployed system. Key destruction is attested, not proven. The retained record is pseudonymised, not anonymous. The legal readings are the author's and are put to the authorities, not assumed.

Arshad Akhtar Abbasia, Høgskolen i Molde, November 2026. Thesis: *Verifiable Crypto-Erasure for Cross-Border Health Data Audit Trails under the European Health Data Space*.

Del 5, notat

Lagring av revisjonsloggen for grensekryssende utveksling: to funn for den dataansvarlige

Skrevet for Helsedirektoratet (dataansvarlig for NCPeH), Datatilsynet og Helse- og omsorgsdepartementet

En grensekryssende utveksling gjennom MyHealth@EU etterlater en revisjonspost som skal oppbevares, slik at den kan revideres, og som pasienten kan be om å få slettet (personvernforordningen artikkel 17). En tilgangslogg i et sikkert analyserom har i tillegg en tredje plikt: sletting senest seks måneder etter at tillatelsen er utløpt (EHDS artikkel 68 nr. 12). Ingen rettsakt sier hvordan disse pliktene henger sammen.

1 **Pilotens seks år er et minstekrav den dataansvarlige har valgt, uten påvist rettsgrunnlag.**

Helsedirektoratet finner ingen lagringstid i eHDSI-spesifikasjonene, som viser til nasjonal lovgivning; seks år er besluttet for utprøvingen, mens lagringstiden i produksjon ikke er fastsatt og er Helsedirektoratets å fastsette som dataansvarlig (vedlegg D). Gjennomføringsforordningen for MyHealth@EU, (EU) 2026/2083, krever at utvekslingene logges, men fastsetter heller ingen lagringstid. Personvernforordningen artikkel 17 nr. 3 bokstav b unntar behandling som er nødvendig for å oppfylle en rettslig forpliktelse, eller en oppgave i allmennhetens interesse, fastsatt i unionsretten eller nasjonal rett. Med mindre det påvises et nasjonalt rettsgrunnlag for de seks årene, har det ikke noe sikkert grunnlag i artikkel 17 nr. 3 bokstav b å beholde pasientkoblingen når pasienten ber om sletting, før EHDS artikkel 9 får anvendelse 26. mars 2029, og etter de 36 månedene den fastsetter.

2 **Oppbevaring og sletting kan begge oppfylles, dersom «verifiserbar» betyr at ansvaret kan etterprøves.**

Må en revisjonspost kunne leses for å regnes som verifiserbar, kan pliktene ikke oppfylles samtidig når en frist faller innenfor lagringstiden. Er det nok å bevare hvem som handlet, når, en kryptografisk binding (commitment) til innholdet og en logget ugyldiggjøring, kan pliktene i modellen oppfylles for hver post: innholdet slettes ved fristen, og posten kan fortsatt kontrolleres. Oppgaven beskriver en mekanisme for dette og kontrollerer den i kode på syntetiske data.

Spørsmål til myndighetene (kapittel 7, avsnitt 7.4)

- Hvilket rettsgrunnlag skal lagringstiden i produksjon bygge på?
- Oppfyller en revisjonspost med ugyldiggjort innhold fortsatt en oppbevaringsplikt?
- Omfatter artikkel 68 nr. 12 tilgangslogger som føres per pasientjournal?

Begrensninger. Resultatene bygger på en formell modell kontrollert på syntetiske data, ikke på et system i drift. Sletting av nøkler er attestert, ikke bevist. Posten som beholdes, er pseudonymisert, ikke anonym. De rettslige tolkningene er forfatterens og legges fram for myndighetene, ikke tatt for gitt.

Arshad Akhtar Abbasia, Høgskolen i Molde, november 2026. Masteroppgave: *Verifiable Crypto-Erasure for Cross-Border Health Data Audit Trails under the European Health Data Space*.